

DOCUMENTACIÓN DE RED Y SISTEMAS

Erronka 1 - Talde 2

Cliente / Organización	<i>Eskola</i>
Proyecto	<i>Erronka1</i>
Versión del documento	<i>1.0</i>
Responsables	<i>Iker Fariñas, Oier Albizu, Mikel Corrales</i>
Fecha	<i>03/10/2026</i>

Control del documento

Historial de versiones

Versión	Fecha	Autor
1.0	03/10/2026	Mikel Corrales
1.1	04/10/2026	Mikel Corrales

Índice

Control del documento	2
Historial de versiones	2
Índice	2
1. Introducción	4
1.1 Propósito	4
1.2 Alcance	4
1.3 Glosario y siglas	4
2. Visión general de la arquitectura	5
2.1 Descripción general	5
2.2 Diagrama de arquitectura	5
2.2.1 Diagrama de red	5
2.2.2 Diagrama de puertos del mikrotik	6
2.2.3 Diagrama de SNAT	7
3. Infraestructura de red	7
3.1 Topología	7
3.2 Direccionamiento IP y VLANs	7
3.3 Dispositivos de red	8
3.4 Enrutamiento y conmutación	8
3.5 DNS, DHCP y NTP	8
3.6 Firewall, reglas de seguridad y NAT	8
3.6.1 Reglas de MikroTik (Router de Borde)	8
3.6.1.1 Rules:	8
3.6.1.2 NAT (Network Address Translation)	10
3.6.2 Reglas de pfSense (Firewall Perimetral)	10
3.6.2.1 Alias IP:	10
3.6.2.2 Alias Port:	11
3.6.2.3 Rules:	11
3.6.2.4 NAT (Network Address Translation)	12
A. Outbound NAT (SNAT)	12
B. Port Forward (DNAT)	13
3.7 Proxies	13
3.8 Justificación de decisiones de diseño	13
4. Sistemas e infraestructura de cómputo	14
4.1 Inventario de servidores	14
4.2 Ficha de servidor (repetir por cada sistema crítico)	14
Ficha 1: Servidor Web (DMZ)	14

Ficha 2: Servidor de Base de Datos (Servidores)	14
Ficha 3: Controlador de Dominio (Servidores)	15
4.3 Aplicaciones y servicios	15
4.4 Bases de datos	15
4.5 Almacenamiento	15
4.6 Virtualización	16
4.7 Despliegue de la aplicación (Docker)	16
5. Seguridad	16
5.1 Identidad y control de acceso	16
5.1.1 Estructura organizativa (OUs y grupos):	16
5.1.2 Políticas de Contraseñas (PSO - Password Settings Objects):	16
5.1.3 Directivas de grupo (GPO)	16
5.1.4 Métodos de Acceso a Servidores:	17
5.2 Bastionado y gestión de parches	18
5.2.1 Bastionado (Hardening):	18
5.2.2 Gestión de Parches:	18
5.3 Antimalware y vulnerabilidades	18
Anexos	19
Anexo A. Matriz de flujos de comunicación	19
Anexo B. Notas adicionales	19

1. Introducción

1.1 Propósito

Este documento tiene como propósito definir, planificar y documentar la infraestructura de red y sistemas necesaria para el desarrollo del **Reto 1: Asentando las bases**. Existe para servir de referencia técnica en las fases de diseño, implementación, operación, soporte y auditoría de la red de la empresa simulada.

El problema que resuelve es la necesidad de disponer de una arquitectura de red segmentada, bastionada y monitorizada, que permita alojar los servicios del proyecto (sitio web, base de datos, gestión de usuarios y cursos) de forma segura, aplicando medidas de prevención, concienciación y respuesta ante incidentes.

1.2 Alcance

Este documento abarca:

- Diseño de la topología de red.
- Segmentación en DMZ, red de usuarios, red de servidores y red de sistemas.
- Direccionamiento IP y configuración de VLANs.
- Bastionado de routers, switches y servidores.
- Configuración de servicios de red y servidores.
- Seguridad perimetral: ACL, NAT, redirección de puertos y filtrado.
- Documentación de evidencias y entregables.

Queda fuera del alcance el desarrollo detallado del software, aunque se contempla su despliegue en la DMZ y su integración con la base de datos ubicada en la red de servidores.

1.3 Glosario y siglas

Término	Definición
VLAN	Red de área local virtual
DMZ	Zona Desmilitarizada
Proxmox VE	Entorno de virtualización de código abierto
Docker	Plataforma de contenedores
Nginx	Servidor web y proxy inverso
PostgreSQL	Sistema de gestión de bases de datos relacional
TLS	Seguridad de la Capa de Transporte
NAT	Network Address Translation (Traducción de Direcciones de Red)
SNAT	Source NAT (NAT de origen, usado para la salida a Internet)
DNAT	Destination NAT (NAT de destino, usado para publicar servicios hacia Internet)
DHCP	Dynamic Host Configuration Protocol (asignación automática de IPs)
DNS	Domain Name System (resolución de nombres de dominio)
NTP	Network Time Protocol (sincronización horaria)
CIDR	Classless Inter-Domain Routing (notación de subredes, ej. /24)

Término	Definición
RFC1918	Estándar que define los rangos de direcciones IP privadas
802.1Q	Estándar de etiquetado de VLANs (trunking)
SSH	Secure Shell (acceso remoto cifrado por línea de comandos)
RDP	Remote Desktop Protocol (escritorio remoto de Windows)
WinRM	Windows Remote Management (gestión remota de Windows por línea de comandos)
AD / AD DS	Active Directory / Active Directory Domain Services (servicio de directorio de Windows)
OU	Organizational Unit (Unidad Organizativa de Active Directory)
GPO	Group Policy Object (Directiva de Grupo)
PSO	Password Settings Object (Objeto de Configuración de Contraseñas)
FQDN	Fully Qualified Domain Name (nombre de dominio completo)
PHP-FPM	PHP FastCGI Process Manager (gestor de procesos PHP usado por Nginx)
Laravel	Framework de desarrollo en PHP usado para la aplicación de matrículas
CRUD	Create, Read, Update, Delete (operaciones básicas sobre una base de datos)
pgAdmin	Herramienta de administración web para PostgreSQL
SPOF	Single Point of Failure (punto único de fallo)
Winbox	Herramienta de administración gráfica de RouterOS (MikroTik)
AZL	Administrazio eta Zerbitzuetako Langileak

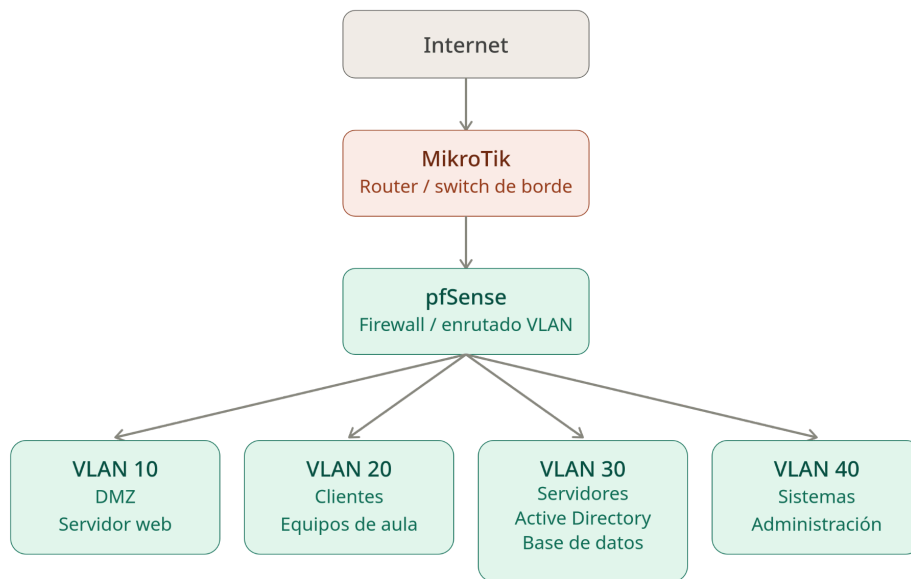
2. Visión general de la arquitectura

2.1 Descripción general

La arquitectura se compone de un router de borde MikroTik que gestiona el tráfico de Internet. Tras él, un firewall perimetral pfSense (virtualizado en Proxmox) segmenta la red en cuatro VLANs: DMZ (10), Clientes (20), Servidores (30) y Sistemas (40). El hipervisor Proxmox aloja las máquinas virtuales críticas, incluyendo el servidor web (Ubuntu + Docker + Nginx) en la DMZ, el servidor de base de datos (Ubuntu + Docker + PostgreSQL) en la red de Servidores y el servidor de windows en la red de Servidores.

2.2 Diagrama de arquitectura

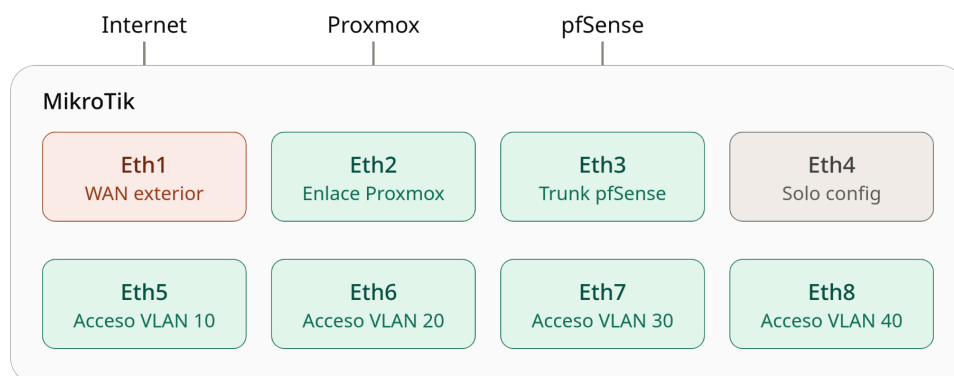
2.2.1 Diagrama de red



Gris = exterior · Coral = borde (MikroTik) · Teal = infraestructura interna

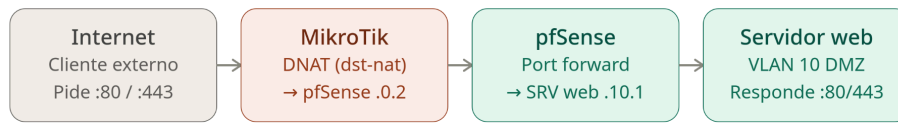
2.2.2 Diagrama de puertos del mikrotik

Puerto físico (MikroTik)	Tipo de puerto	Dispositivo conectado	VLAN
Eth1	WAN (acceso)	Red del proveedor / Internet (192.168.74.0/24)	— (sin etiquetar, red externa)
Eth2	Acceso (LAN)	Proxmox (gestión, 192.168.0.1)	— (red de gestión)
Eth3	Trunk (802.1Q)	pfSense (vtnet1)	10, 20, 30, 40 (etiquetadas)
Eth5	Acceso	Switch/equipos DMZ	10
Eth6	Acceso	Switch/equipos Clientes (aula)	20
Eth7	Acceso	Switch/equipos Servidores	30
Eth8	Acceso	Switch/equipos Sistemas (administración)	40



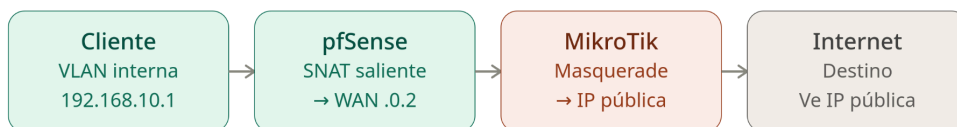
Coral = conexión exterior · Teal = red interna (trunk y acceso) · Gris = sin uso activo

2.2.3 Diagrama de DNAT



Cada salto traduce el destino hasta llegar al servidor real

2.2.3 Diagrama de SNAT



Cada salto traduce el origen; el destino en Internet nunca cambia

3. Infraestructura de red

3.1 Topología

Topología en estrella jerárquica con doble NAT. El router MikroTik actúa como borde de red (Eth1 WAN) conectado a la red del proveedor (192.168.74.0/24), desde donde recibe conectividad a Internet. El MikroTik realiza una primera capa de NAT (masquerade) hacia esa red externa y distribuye el tráfico interno hacia el firewall pfSense a través de un enlace troncal (Eth3 Trunk).

pfSense, virtualizado en Proxmox, realiza una segunda capa de NAT, el enrutamiento inter-VLAN y aplica las políticas de seguridad (firewall) sobre las cuatro VLANs internas: DMZ (10), Clientes (20), Servidores (30) y Sistemas (40). Esta separación en dos capas de NAT permite que el MikroTik actúe como frontera frente a la red externa mientras pfSense centraliza el filtrado y segmentación del tráfico interno.

Los switches de acceso del MikroTik (Eth5-Eth8) conectan los dispositivos finales de cada VLAN (ver diagrama 2.2.2 para el mapeo físico de puertos por VLAN). Los puertos de acceso están configurados para admitir únicamente tráfico de su VLAN correspondiente (frame-types restringido y ingress-filtering habilitado), evitando ataques de VLAN hopping desde los puertos de usuario final.

3.2 Direccionamiento IP y VLANs

VLAN ID	Nombre	Subred (CIDR)	Gateway	DHCP	Zona de seguridad	Propósito
10	DMZ	192.168.10.0/24	192.168.10.254	No	Baja confianza (expuesta a Internet)	Servidor Web (Docker/Nginx)
20	Erabiltzaileak	192.168.20.0/24	192.168.20.254	Si (192.168.20.100 - 192.168.20.250)	Confianza media	Clientes / Equipos de aula

VLAN ID	Nombre	Subred (CIDR)	Gateway	DHCP	Zona de seguridad	Propósito
30	Zerbitzariak	192.168.30.0/24	192.168.30.254	No	Alta confianza	Servidores (AD, Docker/PostgreSQL)
40	Sistemak	192.168.40.0/24	192.168.40.254	No	Administración / Máxima confianza	Administración y Sistemas

3.3 Dispositivos de red

Hostname	Tipo	Fabricante / Modelo	IP gestión	Ubicación	Firmware	Rol
MikroTik	Router/Switch	MikroTik	192.168.0.254	Rack	RouterOS	Borde / NAT
pfSense	Firewall	Netgate (VM)	192.168.0.2	Proxmox	pfSense CE	Firewall / Enrutador
Proxmox	Hipervisor	Proxmox VE 9.2.2	192.168.0.1	Rack	9.2.2	Virtualización

3.4 Enrutamiento y conmutación

Enrutamiento estático entre VLANs gestionado por pfSense. MikroTik realiza NAT (masquerade) hacia Internet. VLAN Trunking (802.1Q) configurado en MikroTik (Eth3) y pfSense (vtnet1).

Los puertos de acceso del MikroTik están configurados con `frame-types=admit-only-untagged-and-priority-tagged` e `ingress-filtering=yes`, de forma que solo aceptan tráfico sin etiquetar de su propia VLAN (asignada vía pvid) y descartan cualquier trama ya etiquetada que intente entrar por un puerto de acceso. El puerto troncal (Eth3) hace lo inverso: solo admite tráfico etiquetado (`admit-only-vlan-tagged`), también con `ingress-filtering` activo. Esta configuración mitiga ataques de VLAN hopping (switch spoofing y double tagging).

3.5 DNS, DHCP y NTP

- **DNS:** Servidor Windows (192.168.30.1) para el dominio talde2.eus. pfSense actúa como DNS Resolver.
- **DHCP:** Gestionado por pfSense en la VLAN 20 (rango 192.168.20.100 - 192.168.20.250).
- **NTP:** pfSense actúa como servidor NTP para las VLANs.

3.6 Firewall, reglas de seguridad y NAT

3.6.1 Reglas de MikroTik (Router de Borde)

3.6.1.1 Rules:

ID	Cadena	Origen	Destino	Servicio / Puerto	Acción	Descripción
0	input	192.168.0.0/24 (vía ether1)	*	*	Drop	anti-spoof LAN por WAN
1	input	*	*	connection-state=esta	Accept	acepta conexiones establecidas

ID	Cadena	Origen	Destino	Servicio / Puerto	Acción	Descripción
				blished,related		
2	input	*	*	connection-state=invalid	Drop	descarta invalidas
3	forward	*	*	connection-state=established,related	Accept	forward establecidas
4	forward	*	*	connection-state=invalid	Drop	forward invalidas
5	input	*	*	TCP (fin,syn)	Drop	bloquea FIN-SYN
6	input	*	*	TCP (syn,rst)	Drop	bloquea SYN-RST
7	input	*	*	TCP (fin,rst)	Drop	bloquea FIN-RST
8	input	*	*	TCP (fin,!ack)	Drop	bloquea FIN sin ACK
9	forward	*	192.168.0.2	TCP/80	Accept	Permitir HTTP a web matrículas
10	forward	* (vía ether1)	192.168.0.2	TCP/443	Accept	Permitir HTTPS a web matrículas
11	input	*	*	TCP (!fin,!syn,!rst,!ack)	Drop	bloquea paquete sin flags (null scan)
12	input	*	*	TCP (psd=21,3s,3,1)	add-src-to-address-list	detecta escaneo (añade a lista port_scanners , timeout 1d)
13	input	src-address-list=port_scanners	*	*	Drop	bloquea escaneadores
14	input	src-address-list=winbox_blacklist	dst-port=8291	TCP (new)	Drop	bloquea intentos winbox
15	input	*	dst-port=8291	TCP (new)	add-src-to-address-list	etapa1 winbox (añade a lista winbox_stage1 , timeout 1m)

ID	Cadena	Origen	Destino	Servicio / Puerto	Acción	Descripción
16	input	src-address-list=winbox_stage1	dst-port=8291	TCP (new)	add-src-to-add-ress-list	bloquea tras repetir (añade a lista winbox_blacklist , timeout 1d)
17	input	* (vía ether1)	dst-address-type=broadcast	*	Drop	bloquea broadcast por WAN
18	input	* (vía ether1)	dst-address-type=multicast	*	Drop	bloquea multicast por WAN
19	input	*	*	ICMP (limit=10,5:packet)	Accept	limita ICMP
20	input	*	*	ICMP	Drop	descarta icmp excedente
21	input	in-interface=ether2	*	*	Accept	permite LAN
22	input	192.168.74.30-192.168.74.60	*	*	Accept	permitir gestion WAN

3.6.1.2 NAT (Network Address Translation)

ID	Origen	Destino	Servicio / Puerto	Acción	Descripción
MTK-NAT-01	192.168.0.0/24 (Red Interna)	WAN (ether1)	Cualquiera	Masquerade (srcnat)	NAT de salida general para permitir Internet a la red interna.
MTK-NAT-02	WAN (Internet)	192.168.0.2 (pfSense)	TCP/80, TCP/443	DST-NAT (dstnat)	Port Forward de HTTP/HTTPS hacia pfSense para su filtrado.

3.6.2 Reglas de pfSense (Firewall Perimetral)

3.6.2.1 Alias IP:

Nombre	Tipo	Valores	Descripción
ADMIN_HOSTS	Host(s)	192.168.40.35, 192.168.40.36, 192.168.40.37, 192.168.40.38	IP de PCs administración
NET_DMZ	Network(s)	192.168.10.0/24	VLAN 10 DMZ
NET_SERVIDORES	Network(s)	192.168.30.0/24	VLAN 30 Servidores
PROXMOX_MGMT	Host(s)	192.168.0.1	Proxmox IP
RFC1918	Network(s)	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16	Redes privadas
SRV_AD	Host(s)	192.168.30.1	Windows server (Servidores)
SRV_UBUNTU_DB	Host(s)	192.168.30.2	Ubuntu server Servidores
SRV_UBUNTU_WEB	Host(s)	192.168.10.1	Ubuntu server DMZ

3.6.2.2 Alias Port:

Nombre	Tipo	Valores	Descripción
AD_PORTS	Port(s)	53, 88, 123, 135, 389, 445, 464, 636, 3268, 3269, 49152:65535	Puertos mínimos para AD (Windows server)
PFSense_GUI_PORTS	Port(s)	443, 80, 22	Puertos de gestión del firewall (GUI, SSH)
PROXMOX_PORTS	Port(s)	22, 8006	Puertos de Proxmox (SSH, Web GUI)
PUERTOS_SERVIDORES	Port(s)	80, 443, 445, 631, 9100, 3389, 22	Puertos de servicios de servidores
WEB_PORTS	Port(s)	80, 443	Puertos web (HTTP/HTTPS)

3.6.2.3 Rules:

ID	Interfaz	Origen	Destino	Puerto	Acción	Descripción
FW-WAN-01	WAN	*	SRV_UBUNTU_WEB	80, 443	Permitir	NAT DMZ - Web NAT
FW-WAN-02	WAN	*	*	*	Bloquear	Bloquear redes bogón
FW-DMZ-01	OPT1 (DMZ)	OPT1 subnets	OPT1 address	53 (DNS)	Permitir	Permitir DNS a pfSense
FW-DMZ-02	OPT1 (DMZ)	OPT1 subnets	This Firewall	GUI Ports	Bloquear	DMZ - Bloquear GUI de pfSense
FW-DMZ-03	OPT1 (DMZ)	SRV_UBUNTU_WEB	SRV_UBUNTU_DB	5432	Permitir	DMZ - Web a base de datos (PostgreSQL)
FW-DMZ-04	OPT1 (DMZ)	*	SRV_UBUNTU_WEB	WEB_PORTS	Permitir	DMZ - Permitir HTTP/HTTPS al servidor web (NAT reflection)
FW-DMZ-05	OPT1 (DMZ)	OPT1 subnets	RFC1918	*	Bloquear	DMZ - Bloquear redes privadas
FW-DMZ-06	OPT1 (DMZ)	OPT1 subnets	*	WEB_PORTS	Permitir	DMZ - Permitir web a Internet
FW-DMZ-07	OPT1 (DMZ)	OPT1 subnets	*	123 (NTP)	Permitir	DMZ - Permitir NTP a Internet
FW-CLI-01	OPT2 (Clientes)	OPT2 subnets	OPT2 address	53 (DNS)	Permitir	Permitir DNS a pfSense
FW-CLI-02	OPT2 (Clientes)	OPT2 subnets	This Firewall	GUI Ports	Bloquear	Clientes - Bloquear GUI de pfSense
FW-CLI-03	OPT2 (Clientes)	OPT2 subnets	NET_SERVIDORES	PUERTOS_SERVIDORES	Permitir	Clientes - Permitir servicios a Servidores
FW-CLI-04	OPT2 (Clientes)	OPT2 subnets	SRV_AD	AD_PORTS	Permitir	Clientes - Permitir AD (unión a dominio)
FW-CLI-05	OPT2 (Clientes)	OPT2 subnets	NET_DMZ	WEB_PORTS	Permitir	Clientes - Permitir web a DMZ

ID	Interfaz	Origen	Destino	Puerto	Acción	Descripción
FW-CLI-06	OPT2 (Clientes)	OPT2 subnets	RFC1918	*	Bloquear	Clientes - Bloquear redes privadas
FW-CLI-07	OPT2 (Clientes)	OPT2 subnets	*	*	Permitir	Clientes - Salida a Internet
FW-SRV-01	OPT3 (Servidores)	OPT3 subnets	OPT3 address	53 (DNS)	Permitir	Permitir DNS a pfSense
FW-SRV-02	OPT3 (Servidores)	OPT3 subnets	This Firewall	GUI Ports	Bloquear	Servidores - Bloquear GUI de pfSense
FW-SRV-03	OPT3 (Servidores)	OPT3 subnets	RFC1918	*	Bloquear	Servidores - Bloquear redes privadas
FW-SRV-04	OPT3 (Servidores)	OPT3 subnets	*	WEB_PORTS	Permitir	Servidores - Permitir web a Internet
FW-SRV-05	OPT3 (Servidores)	OPT3 subnets	*	123 (NTP)	Permitir	Servidores - Permitir NTP a Internet
FW-SIS-01	OPT4 (Sistemas)	OPT4 subnets	OPT4 address	53 (DNS)	Permitir	Permitir DNS a pfSense
FW-SIS-02	OPT4 (Sistemas)	ADMIN_HOSTS	This Firewall	GUI Ports	Permitir	Sistemas - Admin a GUI de pfSense
FW-SIS-03	OPT4 (Sistemas)	OPT4 subnets	This Firewall	GUI Ports	Bloquear	Sistemas - Bloquear GUI de pfSense
FW-SIS-04	OPT4 (Sistemas)	ADMIN_HOSTS	PROXMOX_MGMT	PROXMOX_PORTS	Permitir	Sistemas - Admin a Proxmox
FW-SIS-05	OPT4 (Sistemas)	ADMIN_HOSTS	SRV_UBUNTU_WEB	22 (SSH)	Permitir	Sistemas - Admin SSH a Ubuntu (DMZ)
FW-SIS-06	OPT4 (Sistemas)	ADMIN_HOSTS	SRV_UBUNTU_DB	22 (SSH)	Permitir	Sistemas - Admin SSH a Ubuntu (Servidores)
FW-SIS-07	OPT4 (Sistemas)	ADMIN_HOSTS	SRV_UBUNTU_DB	5050	Permitir	Sistemas - Admin a pgAdmin
FW-SIS-08	OPT4 (Sistemas)	OPT4 subnets	RFC1918	*	Bloquear	Sistemas - Bloquear redes privadas
FW-SIS-09	OPT4 (Sistemas)	OPT4 subnets	*	*	Permitir	Sistemas - Salida a Internet

3.6.2.4 NAT (Network Address Translation)

A. Outbound NAT (SNAT)

ID	Interfaz	Origen	Destino	Puerto Destino	NAT IP	Puerto NAT	Descripción
NAT-OUT-01	WAN	192.168.10.0/24	*	*	WAN address	*	SNAT - DMZ (VLAN 10)

ID	Interfaz	Origen	Destino	Puerto Destino	NAT IP	Puerto NAT	Descripción
NAT-OUT-02	WAN	192.168.20.0/24	*	*	WAN address	*	SNAT - Clientes (VLAN 20)
NAT-OUT-03	WAN	192.168.30.0/24	*	*	WAN address	*	SNAT - Servidores (VLAN 30)
NAT-OUT-04	WAN	192.168.40.0/24	*	*	WAN address	*	SNAT - Sistemas (VLAN 40)

B. Port Forward (DNAT)

ID	Interfaz	Protocolo	Origen	Puerto Origen	Destino	Puerto Destino	NAT IP	Puerto NAT	Descripción
NAT-FWD-01	WAN	TCP	*	*	WAN address	80	SRV_UBUNTU_WEB	80	DMZ - Web NAT (HTTP)
NAT-FWD-02	WAN	TCP	*	*	WAN address	443	SRV_UBUNTU_WEB	443	DMZ - Web NAT (HTTPS)

3.7 Proxies

Nginx actúa como proxy inverso y servidor web dentro del contenedor Docker en la DMZ (192.168.10.1).

3.8 Justificación de decisiones de diseño

A lo largo del proyecto se han tomado una serie de decisiones de arquitectura orientadas a maximizar la seguridad y la segmentación de la red, minimizando la superficie de ataque expuesta. A continuación se justifica cada una de ellas.

Segmentación en 4 VLANs. Se optó por separar la red en cuatro VLANs (DMZ, Clientes, Servidores y Sistemas) en lugar de una red plana, siguiendo el principio de defensa en profundidad. Cada VLAN agrupa dispositivos con un nivel de confianza y una función homogéneos: la DMZ aloja el único servicio expuesto a Internet (la web), de forma que un ataque exitoso contra él queda contenido y no da acceso directo al resto de la red; Clientes aísla los equipos de usuario final, que son el vector de ataque más probable (phishing, malware); Servidores concentra los sistemas críticos (AD, base de datos) a los que solo deben llegar los flujos estrictamente necesarios; y Sistemas se reserva para los equipos y cuentas de administración, con el nivel de acceso más alto y por tanto el más restringido.

Doble NAT (MikroTik + pfSense). Se decidió mantener dos capas de NAT en lugar de que pfSense asumiera también el rol de borde frente a la red externa. El MikroTik actúa como frontera física (conectado directamente a la red del proveedor) y realiza únicamente el NAT de salida general y el reenvío de los puertos 80/443 hacia pfSense; todo el filtrado, las políticas de seguridad y el enrutamiento inter-VLAN quedan centralizados en pfSense. Esta separación de responsabilidades permite que, si en el futuro se cambia o se pierde el equipo de borde, las políticas de seguridad de la red interna no se vean afectadas, y facilita la administración al tener un único punto (pfSense) donde se gestionan las reglas de firewall de todas las VLANs.

Separación de la base de datos en su propia VLAN. Inicialmente se valoró alojar la base de datos en el mismo servidor que la aplicación web, dentro de la DMZ, pero se descartó por motivos de seguridad: al ser la DMZ la única zona expuesta a Internet, cualquier compromiso del servidor web habría dado acceso directo al sistema operativo de la base de datos. Se optó por trasladar la base de datos a la VLAN de Servidores, de forma que el servidor web solo puede alcanzar el puerto de PostgreSQL (5432) mediante una regla de firewall específica (FW-DMZ-03), sin visibilidad del resto del sistema ni de los demás servicios de esa VLAN.

Bastionado de los puertos de acceso del MikroTik (anti VLAN-hopping). Se configuraron los puertos de acceso con **frame-types** restringido e **ingress-filtering** habilitado en lugar de dejar la configuración por defecto, para evitar que un dispositivo conectado a un puerto de una VLAN pudiera inyectar tráfico etiquetado de otra VLAN (double tagging) y saltarse así la segmentación lógica implementada en el firewall.

Bloqueo de redes privadas (RFC1918) en cada VLAN. Se añadió una regla de bloqueo explícita hacia rangos RFC1918 no utilizados en el proyecto en todas las VLANs, para evitar que un cliente mal configurado (por ejemplo, con una IP de DNS manual incorrecta) pudiera generar tráfico hacia redes privadas ajenas al diseño, y para dificultar el movimiento lateral en caso de que un atacante intentase explorar rangos internos no documentados.

Acceso administrativo centralizado en la VLAN de Sistemas (ADMIN_HOSTS). En lugar de permitir el acceso de gestión (SSH, GUI de pfSense, Proxmox, pgAdmin) desde cualquier punto de la red interna, se restringió a un conjunto cerrado de IPs (**ADMIN_HOSTS**) dentro de la VLAN 40, aplicando el principio de mínimo privilegio: solo los equipos de administración pueden alcanzar la gestión de los sistemas críticos, y el resto de VLANs tienen ese acceso explícitamente bloqueado.

4. Sistemas e infraestructura de cómputo

4.1 Inventario de servidores

Hostname	Rol	SO	IP	CPU / RAM / Disco	Entorno	Ubicación
WinServerTald2	AD / DNS	Win Server 2019	192.168.30.1	4 vCPU / 16 GB / 99.4 GB	PROD	Proxmox (VM 101)
Ubu-Server-Web	Web (Docker/Nginx)	Ubuntu	192.168.10.1	2 vCPU / 4 GB / 20 GB	DMZ	Proxmox (VM 102)
Ubu-Server-DB	BD (Docker/Postgre SQL)	Ubuntu	192.168.30.2	2 vCPU / 8 GB / 30 GB	PROD	Proxmox (VM 103)
PfSense	Firewall	FreeBSD	192.168.0.2	2 vCPU / 4 GB / 20 GB	PROD	Proxmox (VM 100)

4.2 Ficha de servidor (repetir por cada sistema crítico)

Ficha 1: Servidor Web (DMZ)

Hostname / FQDN	talde2ubuntu
Función	Servidor web y proxy inverso (Nginx) para la aplicación
Sistema operativo y versión	Ubuntu 24.04 LTS
Plataforma	Proxmox VE (VM 102)
Direcciones IP y VLAN	192.168.10.1 — VLAN 10 (DMZ)
Servicios instalados	Docker, Nginx
Dependencias	Base de datos PostgreSQL (192.168.30.2)
Método de acceso	SSH vía bastión (solo desde IPs de administración en VLAN 40)

Ficha 2: Servidor de Base de Datos (Servidores)

Hostname / FQDN	talde2ubuntutdb
Función	Servidor de base de datos relacional (PostgreSQL)
Sistema operativo y versión	Ubuntu 24.04 LTS
Plataforma	Proxmox VE (VM 103)
Direcciones IP y VLAN	192.168.30.2 — VLAN 30 (Servidores)
Servicios instalados	Docker, PostgreSQL 16
Dependencias	Almacenamiento persistente (volúmenes Docker)
Método de acceso	SSH vía bastión + pgAdmin (puerto 5050 solo desde IPs de administración en VLAN 40)

Ficha 3: Controlador de Dominio (Servidores)

Hostname / FQDN	WinServerTald2 / talde2.eus
Función	Controlador de dominio, DNS y gestión de identidades
Sistema operativo y versión	Windows Server 2019 Standard Evaluation
Plataforma	Proxmox VE (VM 101)
Direcciones IP y VLAN	192.168.30.1 — VLAN 30 (Servidores)
Servicios instalados	AD DS, DNS
Dependencias	Ninguna crítica (servicio base para el resto)
Método de acceso	Desde la interfaz web de proxmox (solo desde IPs de administración en VLAN 40)

4.3 Aplicaciones y servicios

Aplicación	Versión	Servidor	Puerto	URL	Criticidad
Nginx (proxy inverso)	Alpine (Docker)	Ubu-Server-Web	80, 443	https://192.168.74.60	Alta
Matrículas (Laravel)	—	Ubu-Server-Web	9000 (interno, vía PHP-FPM)	— (tras Nginx)	Alta
pgAdmin	4 (latest)	Ubu-Server-DB	5050	http://192.168.30.2:5050	Media

4.4 Bases de datos

Nombre	Motor / versión	Servidor	Criticidad
PostgreSQL (Docker)	PostgreSQL 16	Ubu-Server-DB	Alta

4.5 Almacenamiento

Proxmox utiliza almacenamiento local (local y local-lvm en el nodo talde2).

4.6 Virtualización

Hipervisor: Proxmox VE 9.2.2 en nodo talde2. Redes virtuales: vmbr0, vmbr1, vmbr2.

4.7 Despliegue de la aplicación (Docker)

El servidor web (Ubu-Server-Web) y el servidor de base de datos (Ubu-Server-DB) ejecutan sus servicios en contenedores Docker gestionados mediante Docker Compose. En el servidor web corren los contenedores matriculas-app (Laravel/PHP-FPM) y matriculas-web (Nginx como proxy inverso y terminación TLS). En el servidor de base de datos corren matriculas-db (PostgreSQL) y matriculas-pgadmin (administración web de la BD).

Por motivos de seguridad, la base de datos se separó del servidor web, ubicándola en su propia VLAN (30 - Servidores) en lugar de coexistir en la DMZ junto con la aplicación. De esta forma, si el servidor web (expuesto a Internet) se viera comprometido, el atacante no tendría acceso directo al sistema operativo del servidor de base de datos, solo al puerto de PostgreSQL permitido explícitamente por regla de firewall (FW-DMZ-03).

5. Seguridad

5.1 Identidad y control de acceso

El control de acceso se centraliza a través de Active Directory en el dominio talde2.eus. Se aplican políticas granulares de contraseñas y directivas de grupo (GPO) segmentadas por roles.

5.1.1 Estructura organizativa (OUs y grupos):

OU	Ruta	Contenido	Grupo asociado
Ikastetxea	raíz del dominio	OU raíz del colegio	–
Ikasleak	Ikastetxea/Ikasleak	Usuarios de alumnado	GG_Ikasleak
Irakasleak	Ikastetxea/Irakasleak	Usuarios de profesorado	GG_Irakasleak
AZL	Ikastetxea/AZL	Personal de administración y servicios	GG_AZL
Ekipoak	Ikastetxea/Ekipoak	Equipos (PCs y portátiles)	–

5.1.2 Políticas de Contraseñas (PSO - Password Settings Objects):

Nombre PSO	Precedencia	Longitud Mín.	Historial	Vigencia Máx.	Bloqueo de Cuenta	Aplicado a (Grupo)
PSO_AZL	5	12 caracteres	8	45 días	5 intentos / 30 min	GG_AZL
PSO_Ikasleak	10	8 caracteres	3	180 días	5 intentos / 30 min	GG_Ikasleak
PSO_Irakasleak	20	10 caracteres	5	60 días	5 intentos / 30 min	GG_Irakasleak

Nota: Todas las políticas exigen requisitos de complejidad. La cuenta se bloquea hasta que un administrador la desbloquee manualmente (excepto en PSO_Ikasleak e PSO_Irakasleak que se desbloquea tras 30 minutos).

5.1.3 Directivas de grupo (GPO)

Nombre GPO	Vinculada a (OU)	Qué hace
GPO_AZL_UnidadRed	Ikastetxea/AZL	Conecta/mapea una unidad de red compartida para el personal de administración y servicios
GPO_Eramangarriak_PoliticaEnergia	Ekipoak/Eramangarriak	Política de energía para portátiles (suspensión, apagado de pantalla, ahorro de batería)
GPO_PCAdmin_RedireccionCarpetas	Ekipoak/PC-Administrazioa	Redirección de carpetas de usuario (Escritorio, Documentos) a ubicación de red en los PCs de administración
GPO_PCGelak_Admin_ApagadoProgramado	Ekipoak/PC-Gelak/PC-Gelak-Administrazioa	Apagado programado automático de los equipos del aula de administración fuera del horario lectivo
GPO_PCGelak_Admin_BloqueoUSB	Ekipoak/PC-Gelak/PC-Gelak-Administrazioa	Bloquea dispositivos de almacenamiento USB en los equipos del aula de administración
GPO_PCGelak_Admin_Loopback	Ekipoak/PC-Gelak/PC-Gelak-Administrazioa	Activa el procesamiento Loopback (modo Combinar) para que la configuración de usuario dependa del equipo (aula) y no de la OU del usuario que inicia sesión
GPO_PCGelak_Admin_PanelControl	Ekipoak/PC-Gelak/PC-Gelak-Administrazioa	Restringe el acceso al Panel de Control / Configuración en los equipos del aula de administración
GPO_PCGelak_Admin_SinInstalacion	Ekipoak/PC-Gelak/PC-Gelak-Administrazioa	Impide la instalación de software desde medios extraíbles
GPO_PCGelak_Admin_SinTerminal	Ekipoak/PC-Gelak/PC-Gelak-Administrazioa	Bloquea el acceso a la línea de comandos (cmd/PowerShell) en el aula de administración
GPO_PCGelak_Info_ApagadoFlexible	Ekipoak/PC-Gelak/PC-Gelak-Informatika	Horario de apagado más flexible para el aula de informática (equipos sin las restricciones del aula de administración, ya que el alumnado de informática necesita mayor libertad de uso)
GPO_Ikasleak_Fondo	Ikasleak	Fija el fondo de escritorio institucional para las cuentas de alumnado
GPO_Ikasleak_RedireccionCarpetas	Ikasleak	Redirección de carpetas de usuario a red para el alumnado
GPO_Irakasleak_BloqueoPantalla	Irakasleak	Bloqueo automático de pantalla tras un periodo de inactividad para el profesorado

5.1.4 Métodos de Acceso a Servidores:

Sistema	Método de acceso	Grupo / Rol	Notas
WinServerTald2 (AD)	RDP / WinRM	Administradores	RDP y WinRM deshabilitados; la gestión se realiza directamente desde la web de Proxmox, accesible solo desde VLAN 40.
Ubu-Server-Web	SSH	ADMIN_HOSTS	Solo accesible desde IPs 192.168.40.35-38.
Ubu-Server-DB	SSH	ADMIN_HOSTS	Solo accesible desde IPs 192.168.40.35-38.
Proxmox (talde2)	Web GUI / SSH	root@pam	Acceso restringido a la VLAN 40.

5.2 Bastionado y gestión de parches

5.2.1 Bastionado (Hardening):

- **Windows Server (AD):** Firewall de Windows Defender activado (perfil privado). Escritorio remoto (RDP) y WinRM deshabilitados; la administración del servidor se realiza directamente desde la web de Proxmox, accesible solo desde la VLAN 40. Directivas GPO que restringen la instalación de software y el uso de terminales.
- **Ubuntu (Web/DB):** Acceso SSH restringido únicamente a las IPs de administración (**ADMIN_HOSTS**). Autenticación por contraseña. Contenedores Docker aislados.
- **Proxmox:** Nodo actualizado a la versión 9.2.2. Acceso a la GUI restringido a la VLAN de Sistemas.
- **pfSense:** Reglas de firewall estrictas (bloqueo de redes privadas RFC1918, bloqueo de escaneos, etc.).

5.2.2 Gestión de Parches:

- **Windows:** Windows Update activado. Últimas actualizaciones instaladas el 29/09. Búsqueda de actualizaciones diaria.
- **Ubuntu/Docker:** Actualizaciones de seguridad aplicadas mediante **apt**. Las imágenes Docker se actualizan periódicamente.
- **Proxmox:** Actualizaciones del hipervisor y de los contenedores LXC/VMs gestionadas desde el panel de Proxmox.

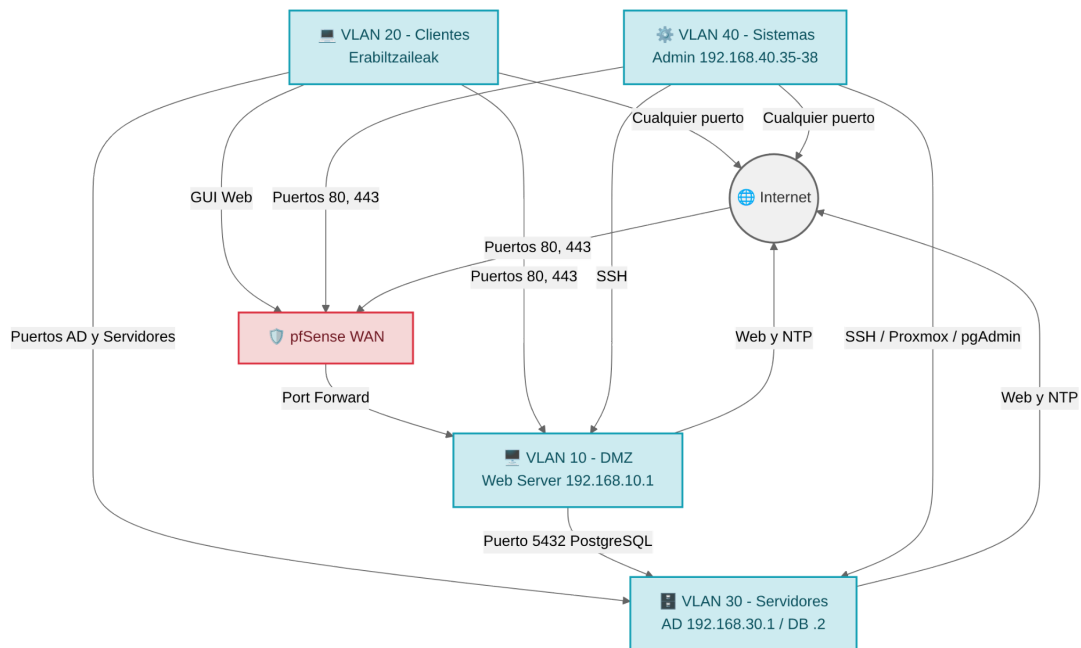
5.3 Antimalware y vulnerabilidades

Windows Server: Windows Defender Antivirus activo y actualizado. Protección en tiempo real habilitada.

Vulnerabilidades: Se recomienda realizar auditorías periódicas de los puertos abiertos en pfSense y revisar los logs de intentos de acceso SSH no autorizados.

Anexos

Anexo A. Matriz de flujos de comunicación



Anexo B. Notas adicionales

El servidor web y la base de datos se ejecutan en contenedores Docker sobre Ubuntu, utilizando Nginx como servidor web y PostgreSQL como motor de base de datos.